

EXECUTIVE SUMMARY

The **AI-Powered Incident Response Orchestration System** is an enterprise-grade platform designed to streamline security incident containment, triage, and response. By integrating an autonomous LLM reasoning agent with strict deterministic workflow execution (LangGraph) and human-in-the-loop approval safeguards, the system reduces Mean Time to Respond (MTTR) by up to 80% while completely mitigating rogue AI execution risks.

1. PRODUCT VISION & STRATEGIC GOALS

Core Objective

Automate end-to-end incident containment (host isolation, IP blocking, credential resets) while ensuring human oversight on high-impact operational changes.

Governance Principles

Strict Governance: The AI Agent proposes and synthesizes insights, but *never* executes commands directly. Execution authority rests with the Orchestration Engine and Human Analysts.

2. TARGET USER PERSONA FRAMEWORK

Role	Primary Responsibilities	System Access & Capabilities
Tier 1 / SOC Analyst	Initial triage, alert verification, manual playbook triggers.	View dashboards, trigger AI analysis, execute low-risk containment steps.
Incident Commander / Manager	High-impact decision making, policy overrides, post-mortem reviews.	Approve/reject high-risk actions (e.g., host isolation, credential locks), export reports.
SecOps Admin	System setup, adapter API integrations, RBAC management.	Full platform configuration, playbook editing, tool adapter credential management.

3. CORE SYSTEM FUNCTIONAL MODULES

1. Alert Ingestion & Parsing Engine

Standardizes raw telemetry from SIEM, EDR, and Firewall alerts into normalized incident schema objects for immediate evaluation.

2. AI Intelligence & Synthesis Agent

Generates natural-language root-cause summaries, evaluates risk scores, and maps alerts to appropriate containment playbooks.

3. LangGraph Orchestration Engine

Manages deterministic state-machine workflow executions, pauses at approval gates, and sequences tool execution steps.

4. Security Tool Adapter Layer

Standardized API integration connectors for EDR (SentinelOne/CrowdStrike), Firewalls (Palo Alto), and Identity providers.

Product Requirements (Cont.)

4. DETAILED FUNCTIONAL REQUIREMENTS

Req ID	Module	Functional Requirement Description	Priority & Risk
FR-01	Alert Ingestion	Ingest HTTP Webhook JSON payloads from SIEM/EDR, validating schema integrity.	P0 - CRITICAL
FR-02	AI Analysis	Synthesize raw alert logs into a concise executive summary and risk rating (0-100).	P0 - CRITICAL
FR-03	Playbook Selection	Recommend the optimal containment playbook based on mapped MITRE ATT&CK tactics.	P0 - CRITICAL
FR-04	Human Approval Gate	Halt playbook state execution when encountering high-risk actions until explicit human signoff.	P0 - HIGH RISK GATE
FR-05	Tool Execution	Dispatch REST API commands to active security adapters upon step authorization.	P0 - CRITICAL
FR-06	Immutable Audit	Record all system, AI, and human actions chronologically into a tamper-proof log.	P1 - HIGH
FR-07	Live Real-Time UI	Broadcast state changes, log feeds, and pending approvals via WebSocket to the dashboard.	P1 - MEDIUM

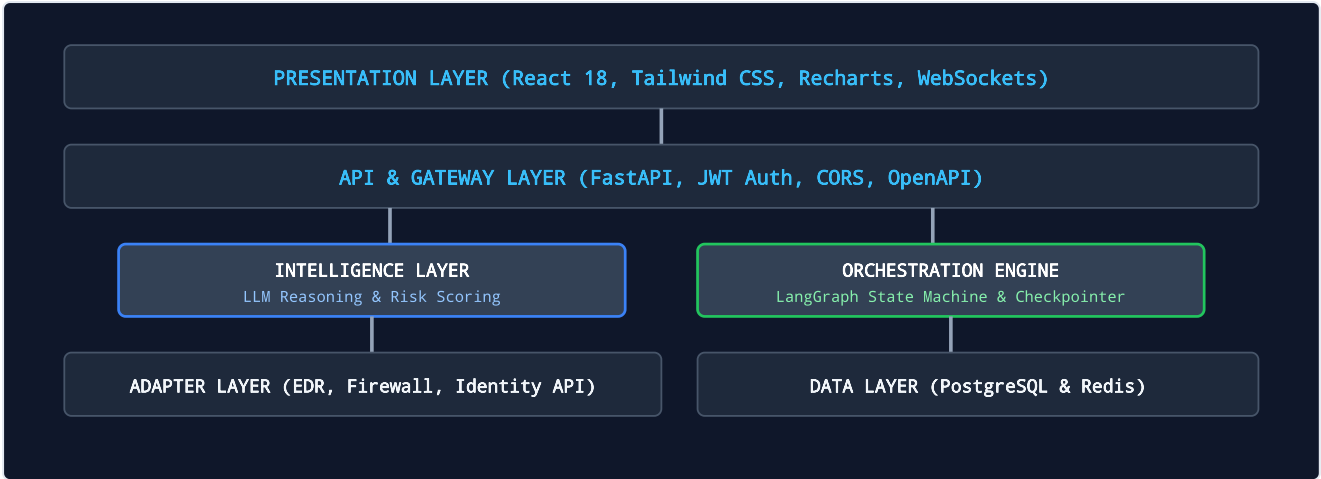
5. END-TO-END OPERATIONAL WORKFLOW SEQUENCE

- Ingestion:** SIEM triggers `POST /api/v1/alerts/ingest` with ransomware detection payload.
- AI Triage:** Intelligence Agent parses context, flags high severity (Risk Score: 88), and proposes `Malware_Response_v1`.
- Orchestration Init:** LangGraph engine builds task graph and begins automated low-risk steps (e.g., hash lookup, IP reputation query).
- Approval Intercept:** Step 3 requires `isolate_endpoint` (High Risk). Engine pauses workflow and triggers real-time WebSocket approval request to Analyst dashboard.
- Human Review:** Analyst reviews AI contextual explanation, verifies hash on threat feeds, and clicks "Approve".
- Execution & Closure:** Adapter isolates host, updates ticket, writes immutable audit record, and sets incident status to `CONTAINED`.

6. KEY SUCCESS METRICS (KPI TARGET OUTCOMES)

Mean Time to Respond (MTTR) Reduce average containment response time from 45 minutes (manual) to < 3 minutes (orchestrated) .	False Positive Mitigation Achieve 100% prevention of unwanted host isolations or network disruptions via mandatory human approval gates.
--	---

7. HIGH-LEVEL ARCHITECTURAL DIAGRAM



8. TECHNOLOGY STACK TECHNICAL RATIONALE

Component	Selected Technology	Technical Justification
Frontend Interface	React 18 + Tailwind CSS	Component isolation, fast rendering of complex state trees, responsive dashboard UX.
API Service	Python 3.11 + FastAPI	High throughput async processing, native integration with AI frameworks, automatic OpenAPI docs.
AI Orchestration	LangGraph + Pydantic	Provides graph-based cyclic workflows, exact schema serialization, and persistent state checkpointing.
Relational Database	PostgreSQL 16	ACID compliance, JSONB field support for raw alert telemetry, relational integrity for audit trails.
Message Bus / Cache	Redis 7	In-memory pub/sub message dispatch for real-time WebSocket dashboard notifications and token storage.

9. POSTGRESQL RELATIONAL SCHEMA DEFINITIONS

The system relies on five core relational entities to maintain system state, execution traces, and audit logs.

```
-- 1. Users & RBAC Authorization
CREATE TABLE users (
  id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  username VARCHAR(50) UNIQUE NOT NULL,
  email VARCHAR(100) UNIQUE NOT NULL,
  hashed_password VARCHAR(255) NOT NULL,
  role VARCHAR(20) NOT NULL CHECK (role IN ('analyst', 'manager', 'admin')),
  created_at TIMESTAMP WITH TIME ZONE DEFAULT CURRENT_TIMESTAMP
);

-- 2. Incidents Master Table
CREATE TABLE incidents (
  id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  title VARCHAR(255) NOT NULL,
  category VARCHAR(50) NOT NULL, -- malware, phishing, unauthorized_access
  severity VARCHAR(20) NOT NULL CHECK (severity IN ('LOW', 'MEDIUM', 'HIGH', 'CRITICAL')),
  status VARCHAR(20) NOT NULL CHECK (status IN ('OPEN', 'INVESTIGATING', 'CONTAINED', 'RESOLVED', 'CLOSED')),
  affected_asset_id VARCHAR(100) NOT NULL,
  raw_alert_data JSONB NOT NULL,
  ai_summary TEXT,
  created_at TIMESTAMP WITH TIME ZONE DEFAULT CURRENT_TIMESTAMP
);

-- 3. Playbook Execution Graph Instances
CREATE TABLE playbook_executions (
  id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  incident_id UUID REFERENCES incidents(id) ON DELETE CASCADE,
  playbook_name VARCHAR(100) NOT NULL,
  current_step_index INT DEFAULT 0,
  status VARCHAR(20) NOT NULL CHECK (status IN ('PENDING', 'RUNNING', 'AWAITING_APPROVAL', 'COMPLETED', 'FAILED')),
  execution_state JSONB NOT NULL, -- LangGraph State Checkpoint Snapshot
  updated_at TIMESTAMP WITH TIME ZONE DEFAULT CURRENT_TIMESTAMP
);

-- 4. Playbook Atomic Execution Tasks
CREATE TABLE playbook_tasks (
  id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  execution_id UUID REFERENCES playbook_executions(id) ON DELETE CASCADE,
  task_name VARCHAR(100) NOT NULL,
  action_type VARCHAR(50) NOT NULL, -- isolate_endpoint, block_ip, revoke_session
  risk_level VARCHAR(20) NOT NULL CHECK (risk_level IN ('LOW', 'HIGH')),
  requires_approval BOOLEAN DEFAULT FALSE,
  approval_status VARCHAR(20) CHECK (approval_status IN ('PENDING', 'APPROVED', 'REJECTED', 'NOT_REQUIRED')),
  approved_by UUID REFERENCES users(id),
  execution_result JSONB
);

-- 5. Write-Only Immutable Audit Log
CREATE TABLE audit_logs (
  id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  incident_id UUID REFERENCES incidents(id) ON DELETE CASCADE,
  actor_id UUID REFERENCES users(id),
  actor_type VARCHAR(20) NOT NULL CHECK (actor_type IN ('SYSTEM', 'AI_AGENT', 'HUMAN_USER')),
  action_performed VARCHAR(100) NOT NULL,
  details JSONB NOT NULL,
  timestamp TIMESTAMP WITH TIME ZONE DEFAULT CURRENT_TIMESTAMP
);
```

REST API Specifications

API ENDPOINTS, CONTRACTS & PAYLOADS

Part II: Technical Specifications

10. INGESTION & INCIDENT MANAGEMENT API

POST /api/v1/alerts/ingest

Description: Accepts incoming webhook alerts from security monitoring infrastructure.

```
// Request Body Payload
{
  "source": "SentinelOne_EDR",
  "alert_id": "ALT-90821",
  "category": "malware",
  "severity": "HIGH",
  "affected_host": "FINANCE-PC-102",
  "asset_ip": "192.168.1.45",
  "details": {
    "file_hash": "e3b0c44298fc1c149afb4c8996fb92427ae41e4649b934ca495991b7852b855",
    "threat_name": "Trojan.Ransomware.Gen"
  }
}

// Response 201 Created
{
  "incident_id": "8f3b21a4-901b-4f5a-bc82-0129f1234a9d",
  "status": "OPEN",
  "message": "Alert successfully ingested and queued for analysis."
}
```

11. AI TRIAGE & ORCHESTRATION API

POST /api/v1/incidents/{incident_id}/analyze

Description: Triggers LLM analysis to parse alert details and propose containment playbooks.

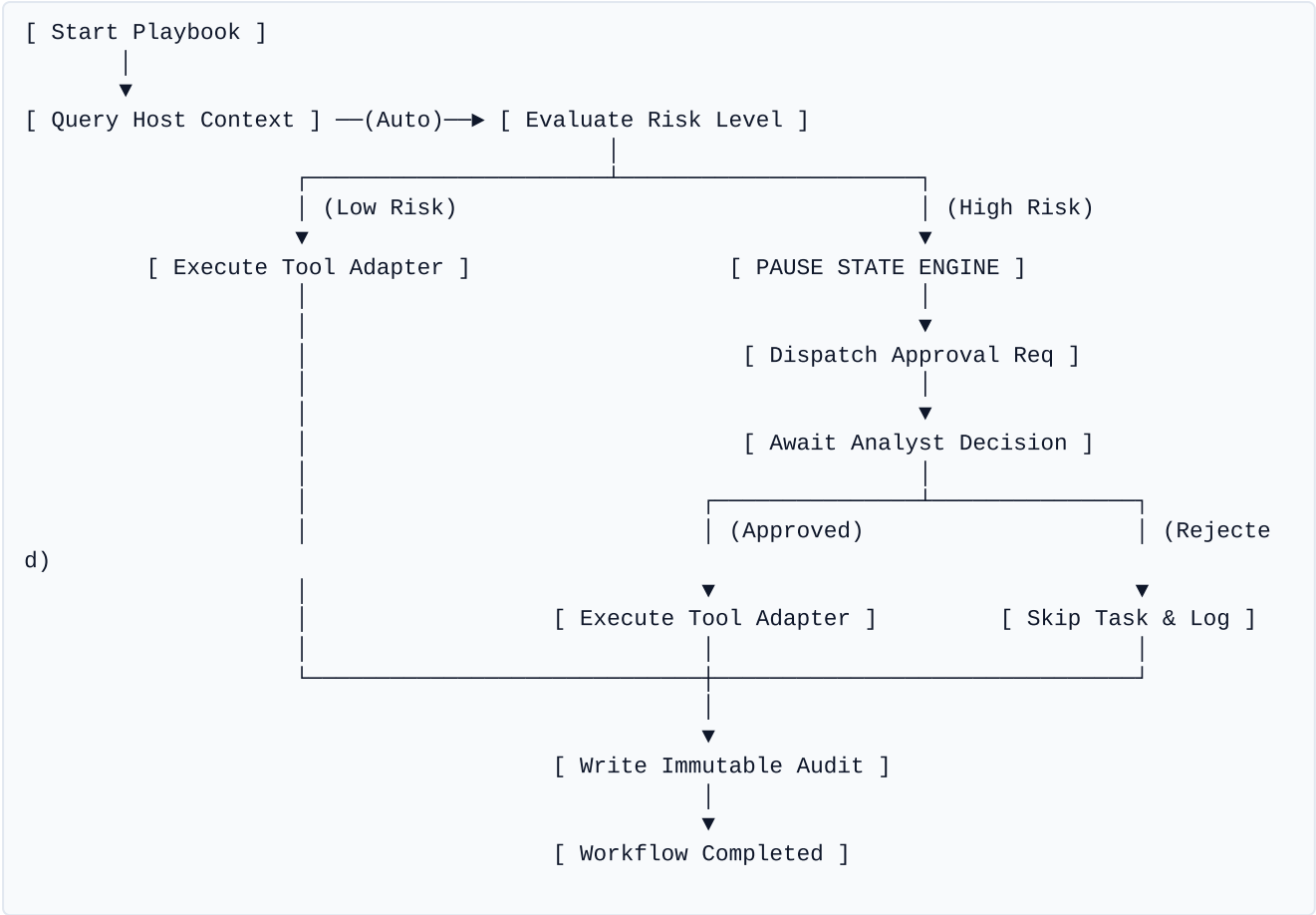
```
// Response 200 OK
{
  "incident_id": "8f3b21a4-901b-4f5a-bc82-0129f1234a9d",
  "risk_score": 88,
  "summary": "High-confidence Trojan detection on FINANCE-PC-102. Risk of lateral movement.",
  "recommended_playbook": "Malware_Response_v1",
  "suggested_actions": [
    {"action": "lookup_hash", "risk": "LOW"},
    {"action": "isolate_endpoint", "risk": "HIGH"}
  ]
}
```

POST /api/v1/approvals/{task_id}/decision

Description: Submits human decision for a pending workflow approval gate.

```
// Request Body Payload
{
  "decision": "APPROVED", // APPROVED | REJECTED
  "analyst_notes": "Verified malicious hash via VirusTotal. Host isolation authorized."
}
```

12. LANGGRAPH EXECUTION STATE MACHINE



13. SECURITY CONTROLS & GOVERNANCE MATRIX

1. Execution Boundary Safeguard The AI Agent functions strictly as a decision-support module. It lacks direct API execution access to infrastructure adapters.	2. Role-Based Access (RBAC) Approval endpoints require authenticated sessions with manager or admin roles. Standard analyst accounts cannot approve high-risk tasks.
3. Write-Only Audit Integrity The audit_logs table restricts SQL permissions to INSERT and SELECT. Modifications and deletions are blocked at the DB level.	4. Secrets Vault Management All tool credentials (EDR tokens, firewall API keys) are injected via secret vaults at startup and never exposed over API interfaces.

14. SIGN-OFF & APPROVAL AUTHORIZATION

Stakeholder Role	Name & Title	Status	Date
VP of Information Security	E. Vance, CISSP	APPROVED	Oct 24, 2026
Lead Security Architect	M. Sterling, CISM	APPROVED	Oct 24, 2026
Principal Software Engineer	D. Kovač, PhD	APPROVED	Oct 25, 2026